



Information Security Management System (ISMS)

ICT infrastructure (ITR-ICTInfra)

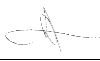
General information

Type	Standard
Reference	#820A
Version	2.2
State	Final
Owner	C. Harpes
Application date	30/01/2025
Classification	Restricted (RE)

Document history

Version	Date	Author	Modifications
1.0	31/03/2013	C. Harpes	Validation
1.1	04/04/2013	A. McKinnon	Editorial modifications based on comments by MMA
1.2	04/04/2013	C. Harpes	Validation
1.3	28/08/2014	B. Jager	Updated port connection
1.4	31/07/2015	C. Harpes	Minor editorial changes
1.5	17/03/2017	C. Harpes	Validation
1.6	08/05/2017	C. Harpes	Validation
1.7	28/07/2017	C. Harpes	Validation
1.8	20/06/2019	A. Deudon	Review of content, styles and validation by MD
1.9	20/06/2019	A. Deudon	Change id from 13-2-A to 13-1-A ...
2.0	08/04/2021	A. Deudon	Adding signature fields in approval table, CC performed according to ticket #5512 and document finalization
2.1	02/05/2023	R. Pande	Updating the document for migration to 27002-2022
2.1.1	14/06/2024	R. Pande	Changed the infrastructure diagram for addition of VLAN CYFort
2.1.3	15/07/2024	R. Pande	Updated infra diagram adding ALAB.
2.1.4	24/07/2024	E. Omar	Review document added 3.1.7
2.1.5	03/09/2024	R. Pande&E. Omar	Updated table 4 Technologies and other minor issues
2.2	03/09/2024	R. Pande	Prepared final version for signatures
2.2.0.1	14/10/2024	C. Houssein	Revision (in TS)
2.2.0.2	29/01/2025	R. Pande	CC check – Found references to old projects; ELK replaced by wazuh. All NCs handled in the document in track changes. NW doesn't have any change this year.
2.3	29/01/2025	R. Pande	Final version for signatures

Approval

Name	Role	Responsibility	Signature
E. Omar	CIO	Content agreement	 Recoverable Signature  X Ensufudine Omar CIO Signed by: 9bbcdf11-ca74-4c8e-beb2-7313f5dd7f3f
R. Pande	SSM	ISO conformity	 Recoverable Signature  X R. Pande SSM Signed by: b04dafe6-cd69-429f-99f5-60a6bdc0fee2
C. Harpes	Managing Director	Applicability	 Revoked certificate  X Carlo Harpes MD Signed by: Carlo Harpes

Management summary

This standard describes the network architecture of itrust consulting at Niederaanven and Berbourg site.

Table of contents

1	Introduction	6
1.1	Context of this document.....	6
1.2	Objectives of the mission	6
1.3	Document structure	6
1.4	References	6
1.5	Acronyms.....	7
1.6	Glossary	8
2	Network architecture	10
2.1	Description of the general architecture	10
2.2	Berbourg network.....	11
2.3	Niederanven network.....	11
2.3.1	Employees network (EN) – 192.168.1.0/24	12
2.3.2	Server and administration network (SAAN) – 192.168.0.0/24	12
2.3.3	DMZ network (DN) – 192.168.4.0/24.....	13
2.3.4	Wi-Fi network (WFN) – 192.168.3.0/24.....	13
2.3.5	VPN network (VPN) – 10.0.2.0/24	13
2.3.6	ALAB network – 192.168.0.15	14
2.3.7	Summary of different network.....	14
2.3.8	Port connections	14
3	Security mechanisms	15
3.1	Network segregation	15
3.1.1	From the EN.....	15
3.1.2	From the SAAN.....	16
3.1.3	From the VN.....	17
3.1.4	From the WFN.....	18
3.1.5	From the DN	19
3.1.6	From the Internet.....	19
3.1.7	From ALab to itrust	20
3.2	From itrust to ALab	20
3.3	Opened ports	21
3.4	Proxy.....	21
3.5	VPN access.....	21
3.6	HTTPS.....	22
3.7	Reverse proxies	22
3.8	Monitoring of the network	22
3.9	Deployment server scheme.....	22
4	Technologies.....	23

List of figures

Figure 1: General logical network	10
Figure 2: Berbourg network.....	11
Figure 3: Niederanven logical network	12
Figure 4: EN white rules.....	15
Figure 5: SAAN white rules	16
Figure 6: VN white rules.....	17
Figure 7: WFN white rules	18

Figure 8: DN white rules	19
Figure 9: Network flow from ALab to itrust	20
Figure 10: Network flow itrust to ALab	21

List of tables

Table 1: Summary of different network sub-nets	14
Table 2: Open/listening ports on the Internet	21
Table 3: Technologies used	24

1 Introduction

1.1 Context of this document

This document belongs to the IT documentation of the Information Security Management System of itrust consulting and focuses on the description of technical aspects of the Information Security Management System.

1.2 Objectives of the mission

The objective of the document is to:

- describe the network architecture deployed at Niederanven and Berbourg;
- provide a port connection plan of the Niederanven site.

1.3 Document structure

The remainder of this document is structured as follows:

- Chapter 2 describes the network architecture of itrust consulting. It contains a description of the logical network and a description of the port connections of the main site of itrust consulting located at Niederanven.
- Chapter 3 describes what security mechanisms are used to protect the confidentiality, integrity and availability of the elements of the network.
- Chapter 4 presents the technologies used to operate the network and the security mechanisms.

1.4 References

- [1] itrust consulting, ISMS, Glossary (ITR-Glossary), #oD.
- [2] itrust consulting, ISMS, ICT inventory (ITR-ICTInventory), <https://snipeit.itrust.lu/>
- [3] itrust consulting, ISMS, ITR (ITR-NewPortConf), #514B.
- [4] Wikipedia, The Free Encyclopedia, Server Message Block, http://en.wikipedia.org/wiki/Server_Message_Block.
- [5] Wikipedia, The Free Encyclopedia, Virtual private network, http://en.wikipedia.org/wiki/Virtual_private_network.
- [6] Wikipedia, The Free Encyclopedia, Dynamic Host Configuration Protocol, http://en.wikipedia.org/wiki/Dynamic_Host_Configuration_Protocol.
- [7] Wikipedia, The Free Encyclopedia, Web server, http://en.wikipedia.org/wiki/Web_server.
- [8] Wikipedia, The Free Encyclopedia, Software versioning, http://en.wikipedia.org/wiki/Software_versioning.
- [9] Wikipedia, The Free Encyclopedia, Backup, <http://en.wikipedia.org/wiki/Backup>.
- [10] Wikipedia, The Free Encyclopedia, DMZ (computing), [http://en.wikipedia.org/wiki/DMZ_\(computing\)](http://en.wikipedia.org/wiki/DMZ_(computing)).

- [11] Synchronization, storage, and sharing software, Teamdrive, <https://www.teamdrive.com/en/>.
- [12] Inspection générale de la sécurité sociale, IGSS, <http://www.mss.public.lu/acteurs/igss/>.
- [13] The open web application security project (OWASP), <https://www.owasp.org/index.php/>.
- [14] Remote and local file copying tool rsync, <https://linux.die.net/man/1/rsync>.
- [15] Open source software suite samba, <https://www.samba.org/>.
- [16] Setup cryptographic volumes cryptsetup / luks, <https://linux.die.net/man/8/cryptsetup>.
- [17] Packet filtering framework, Netfilter, <https://www.netfilter.org/>.
- [18] Open source java platform, openjdk, <http://openjdk.java.net/>.
- [19] Rocket fast system for log processing, rsyslog, <http://www.rsyslog.com/>.
- [20] Elasticsearch, logstash and kibana, elk, <https://www.elastic.co/>.
- [21] Web caching proxy, squid, <http://www.squid-cache.org/>.
- [22] Open source HTTP server, apache, <https://httpd.apache.org/>.
- [23] Open source distributed version control system, gitlab, <https://gitlab.itrust.lu/>.
- [24] Free operating system, Debian, <https://www.debian.org/releases/wheezy/>.
- [25] Open source software for java implementation, apache tomcat, <http://tomcat.apache.org/>.
- [26] Shell for interactive use, zsh, <http://www.zsh.org/>.
- [27] Virtualization product, virtualbox, <https://www.virtualbox.org/>.
- [28] VPN Tunnel, WireGuard, <https://www.wireguard.com/>.
- [29] URL redirector, Squidguard, <http://www.squidguard.org/>.
- [30] Monitorer, Wazuh, <https://wazuh.itrust.lu/>.
- [31] Monitor availability of services, <https://icinga.com/>.
- [32] Loadbalancer for EpStan, <https://www.haproxy.org/>.
- [33] Open source distributed version control system, github, <https://github.com/itrust-consulting>.
- [34] Containerization, docker, <https://www.docker.com/>.
- [35] Containerization, kubernetes, <https://kubernetes.io/>.

1.5 Acronyms

CIFS	Common Internet File System
CIO	Chief Information Officer
CO	Confidential
DHCP	Dynamic Host Configuration Protocol
DMZ	Demilitarized zone
DNS	Domain Name System
ÉpStan	Épreuves Standardisées (https://www.epstan.lu)
GNU	GNU's Not Unix
IGSS	Inspection Générale de la Sécurité Sociale
IN	Internal
IP	Internet Protocol
ISC	Internet Systems Consortium
ISMS	Information Security Management System

IT	Information Technology
LAN	Local Area Network
OS	Operating System
OWASP	The Open Web Application Security Project
SMB	Service Message Block
SSH	Secure Shell
SVN	Subversion
TCP	Transmission Control Protocol
TTP	Trusted Third Party
UDP	User Datagram Protocol
UL	University of Luxembourg
URL	Uniform Resource Locator
VNC	Virtual Network Computing
VPN	Virtual Private Network
Wi-Fi	Wireless Fidelity

1.6 Glossary

Data backup	In information technology, a backup, or the process of backing up, refers to the copying and archiving of computer data so it may be used to restore the original after a data loss event. The verb form is to back up in two words, whereas the noun is backup. See [9].
Demilitarized zone	In computer security, a DMZ (sometimes referred to as a perimeter network) is a physical or logical subnetwork that contains and exposes an organization's external-facing services to a larger untrusted network, usually the Internet. The purpose of a DMZ is to add an additional layer of security to an organization's local area network (LAN); an external attacker only has access to equipment in the DMZ, rather than any other part of the network. The name is derived from the term "demilitarized zone", an area between nation states in which military action is not permitted. See [10]
Dynamic Host Configuration Protocol	The Dynamic Host Configuration Protocol (DHCP) is a network protocol that is used to configure network devices so that they can communicate on an IP network. A DHCP client uses the DHCP protocol to acquire configuration information, such as an IP address, a default route and one or more DNS server addresses from a DHCP server. The DHCP client then uses this information to configure its host. Once the configuration process is complete, the host is able to communicate on the internet. See [6].
SMB domain	In computer networking, Server Message Block (SMB), also known as Common Internet File System (CIFS) operates as an application-layer network protocol mainly used for providing shared access to files, printers, serial ports, and miscellaneous communications between nodes on a network. It also provides an authenticated inter-process communication mechanism. Most usage of SMB involves computers running Microsoft Windows, where it was known as "Microsoft Windows Network" before the subsequent introduction of Active Directory. Corresponding Windows services are the "Server Service" (for the server component) and "Workstation Service" (for the client component). See [4].
Software versioning	Software versioning is the process of assigning either unique version names or unique version numbers to unique states of computer software. Within a given version number category (major, minor), these numbers are generally assigned in increasing order and correspond to new developments in the software. At a fine-grained level, revision control is often used for keeping track of incrementally different versions of electronic information, whether or not this information is actually computer software. See [8].
Virtual Private Network	A virtual private network (VPN) is a technology for using the Internet or another intermediate network to connect computers to isolated remote computer networks that would otherwise be inaccessible. A VPN provides varying levels of security so that traffic sent through the VPN

	connection stays isolated from other computers on the intermediate network, either through the use of a dedicated connection from one "end" of the VPN to the other, or through encryption. VPNs can connect individual users to a remote network or connect multiple networks together. See [5].
Web server	Web server can refer to either the hardware (the computer) or the software (the computer application) that helps to deliver Web content that can be accessed through the Internet. See [7].

For other descriptions of common terms used in this policy, please refer to the general glossary of itrust consulting [1].

2 Network architecture

This chapter describes the network architecture of itrust consulting. The chapter contains a description of the logical network and a description of the port connections of the main site of itrust consulting located in Niederanven.

2.1 Description of the general architecture

The general network architecture of itrust consulting is split into two network sites (see Figure 1), both connected on the Internet:

- Niederanven site: it is the main site of itrust consulting where employees work most of the time. It also contains the main network components such as web servers opened on the Internet, and most of the reference data;
- Berbourg site: it is the secondary site of itrust consulting. Only sporadic work is made at this place. This site also stores a backup of online data of itrust consulting, and act as backup site for ÉpStan service;
- Gandi site: it is a webserver machine hosted by Gandi provider and used to provide websites (e.g. itrust.lu, cockpiti.eu) to customers, and to provide load balancer for ÉpStan service;
- OVH site: it is a server hosted by OVH and used to operate an Icingaz instance to do monitoring of itrust's services.

The figures in the next chapters depict the different detail levels of network architecture of itrust consulting.

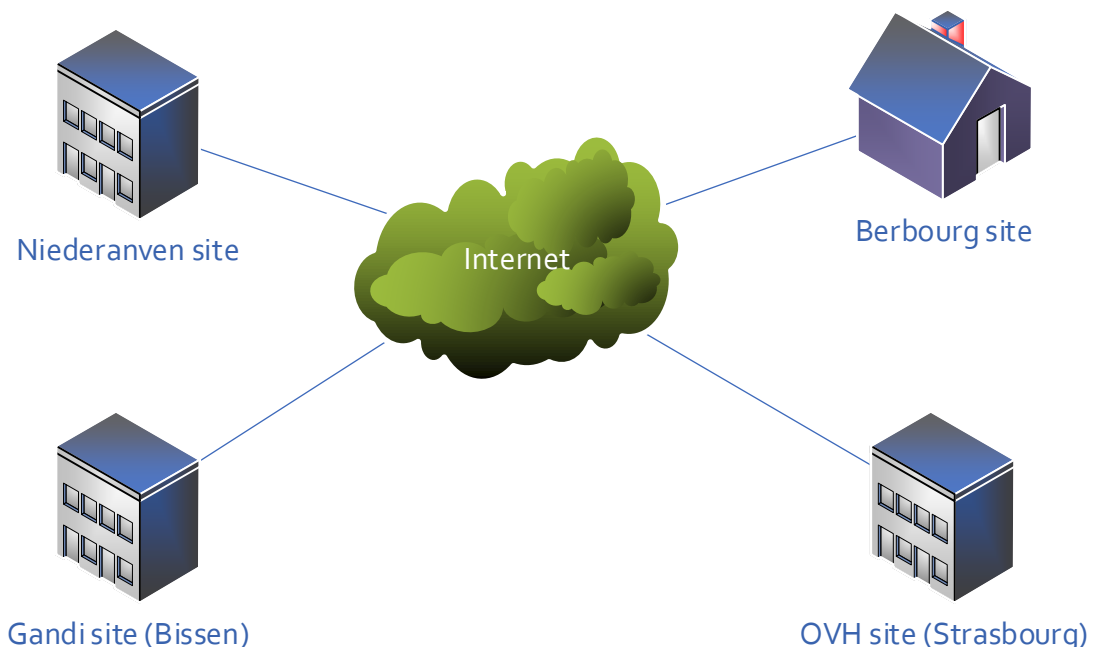


Figure 1: General logical network

2.2 Berbourg network

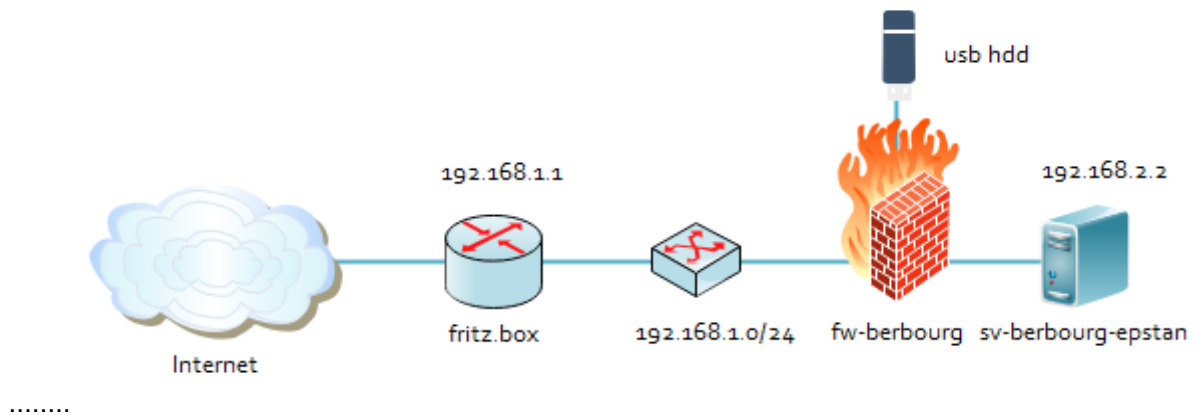


Figure 2: Berbourg network

2.3 Niederaanven network

Niederaanven network (see Figure 3) has been separated into five main sub-networks:

- DMZ network (DN): this network hosts services (e.g. ÉpStan TTP service) to be provided on the Internet;
- Wi-Fi network (WFN): the Wi-Fi network can be used by employees and guests to access the Internet;
- Employee network (EN): this network contains the machines of the employees;
- Server and administration network (SAAN): this network hosts the servers which are critical and only to be provided to the employees. It also hosts the ICT administrators;
- VPN network (VN): this network contains employee devices connected through WireGuard.

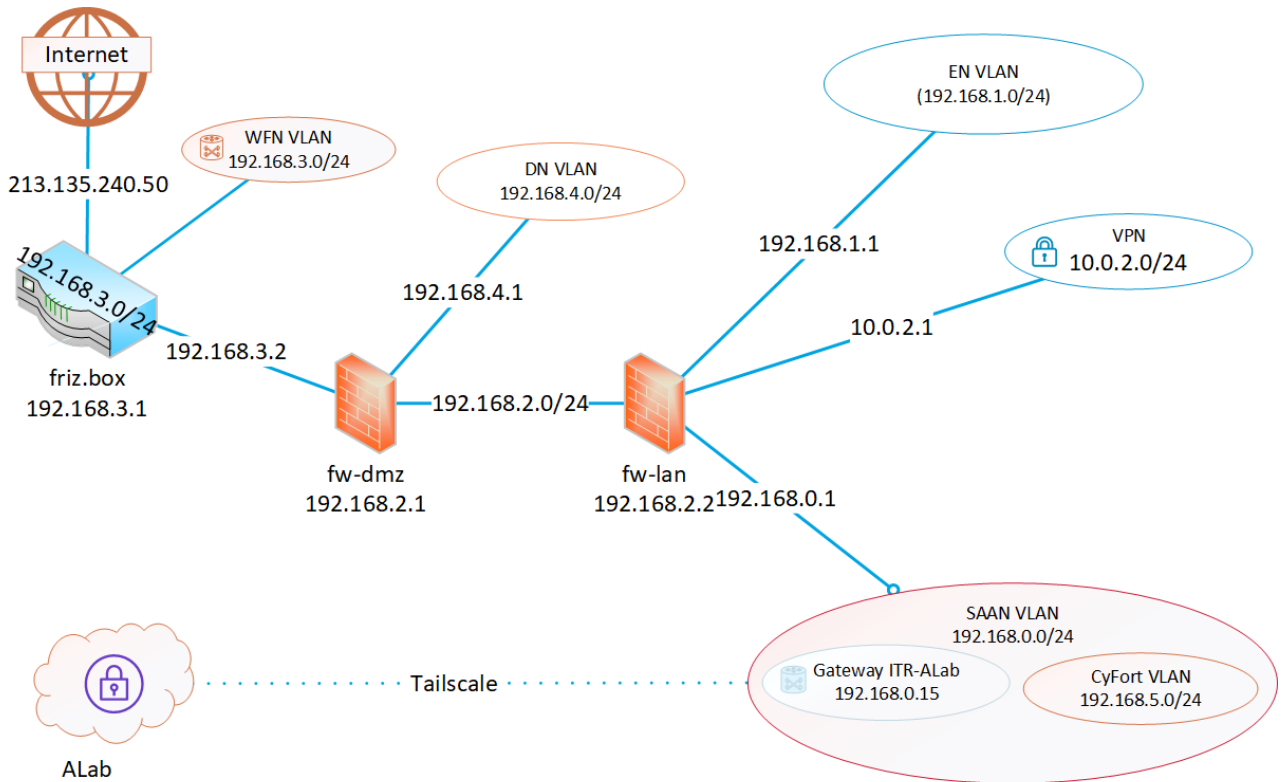


Figure 3: Niederanven logical network

We use two different network numberings for internal and external connections. 192.168.x.o network numbering denotes the local network of Niederanven, and 10.o.x.o network numbering denotes the external network, i.e. connection point where devices connecting to it can (VPN) or could (WFN) be outside of the Niederanven network.

2.3.1 Employees network (EN) – 192.168.1.0/24

The employees' network must only be accessed by employees. From this network, employees only have access to the Internet and the services provided by the server and administration network. Access to the DMZ services is done through a reverse proxy located in the server and administration network.

2.3.2 Server and administration network (SAAN) – 192.168.0.0/24

The server and administration network contains the main services provided to employees. It contains for example the share of data (CO, IN) and the Redmine service. ICT administrators are connected to this network and can thus access the different administration ports (e.g. SSH) of the different services and servers located in the entire network (including those in the DMZ).

Services provided to employees by the server and administration network include (the list is not exhaustive):

- Share: this service provides sharing capabilities between different employees;
- Redmine: a ticketing service for managing issues in projects;
- Gitlab server to maintain a central git repository;
- Wiki: a wiki to maintain documentation on IT management;

2.3.3 DMZ network (DN) – 192.168.4.0/24

A DMZ network primary goal is to provide services to the Internet while protecting internal LAN, using sub-network separation. Therefore, it must only contain services that need to be provided on the Internet for commercial or research projects of itrust consulting. Current services that are provided include (the list is not exhaustive):

- TRICK Service demo: version deployed for use by testers;
- ÉpStan server, which provides access to the ÉpStan TTP service.

Components located in the DN can only access the Internet.

2.3.4 Wi-Fi network (WFN) – 192.168.3.0/24

The Wi-Fi network is dedicated to connecting the mobile devices of employees and guests to the Internet. If employees want to access data and/or services of the server and administration network, they must connect to the VPN.

The DHCP currently assigns the IP addresses in range from 192.168.3.100 to 192.168.3.150 to the connected devices on wifi network.

2.3.5 VPN network (VPN) – 10.0.2.0/24

The VPN network is the network from which employees can access itrust consulting's network from outside (generally from their house or when working from a customer's network). This network can only access the Internet and the services provided by the SAAN.

2.3.6 ALAB network – 192.168.0.15

The vm-lan-bastion-cyfort acts as a Gateway to connect ALAB network to itrust network.

2.3.7 Summary of different network

Network	Addressing	User
Wi-Fi network	Range: 192.168.3.100 to 192.168.3.150	Employee and guests
Server and administration network	192.168.0.0/24	Employee through service ports Administrators through administration ports
VPN network	10.0.2.0/24	Employee
Employees network	192.168.1.0/24	Employee
Between fwlan and fwdmz	192.168.2.0/24	/
Between fwdmz and Router	192.168.3.0/24	/
DMZ network	192.168.4.0/24	Outside world
CyFORT VLAN	192.168.5.0/24	CyFORT network

Table 1: Summary of different network sub-nets

2.3.8 Port connections

Please refer to document 514B_ITR-PortConf [3].

3 Security mechanisms

Different security mechanisms are implemented in the network architecture in order to comply with confidentiality, integrity and availability requirements.

3.1 Network segregation

The segregation between the different networks is made with two firewalls (fw-lan and fw-dmz). These firewalls each apply white rules policies, which mean that by default all traffic is dropped. Traffic initiated by the firewalls themselves is authorised in order to let them communicate with the Internet.

These primary firewall rules are also applied by all servers operating in the network: if a service is provided by a server (e.g. web service, SMB), an additional firewall rule is applied to authorise external connection on the port(s) of the service.

3.1.1 From the EN

From the EN, components can access the Internet and the services provided by the SAAN. Access to the Internet is possible because fw-lan and fw-dmz forward traffic coming from internal networks.

In order to access the services provided by the DN, components of the EN must use the reverse proxy located in the SAAN.

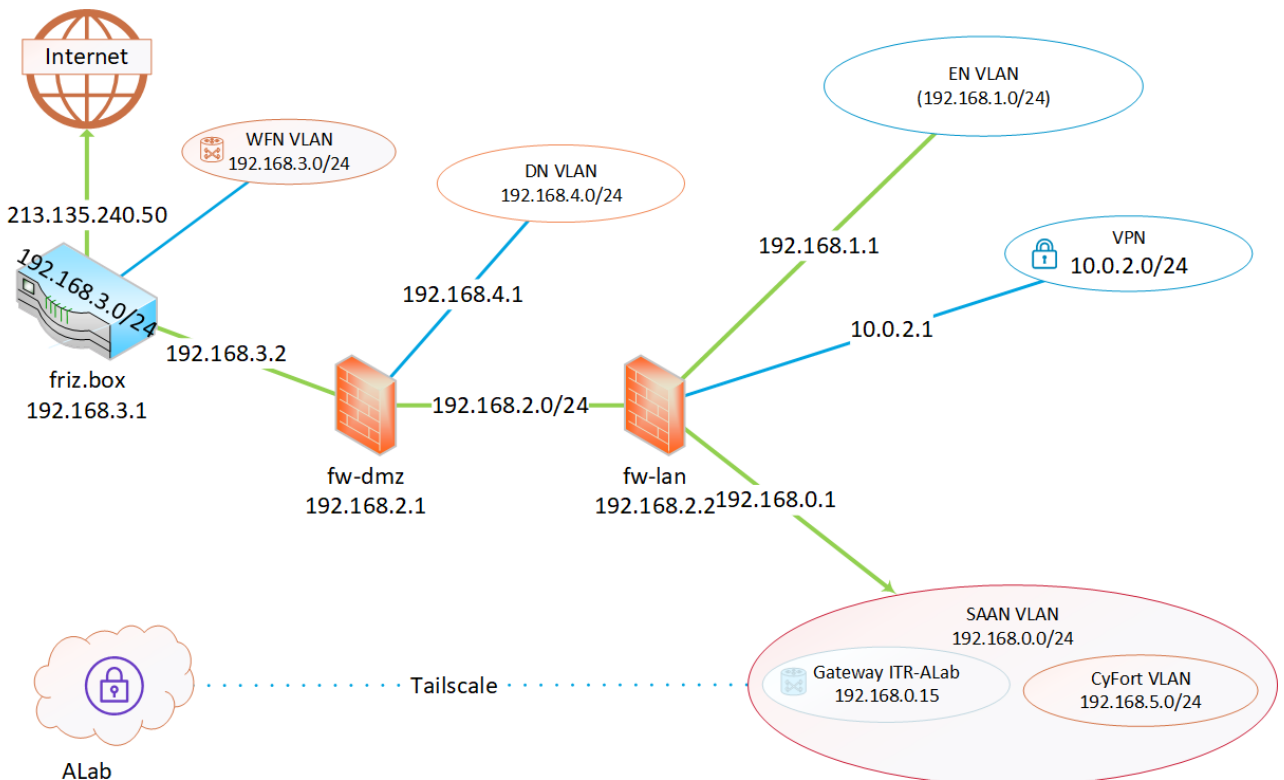


Figure 4: EN white rules

3.1.2 From the SAAN

From the SAAN, components can access the DN network, fw-lan and fw-dmz firewalls, Fritz.box, and the Internet.

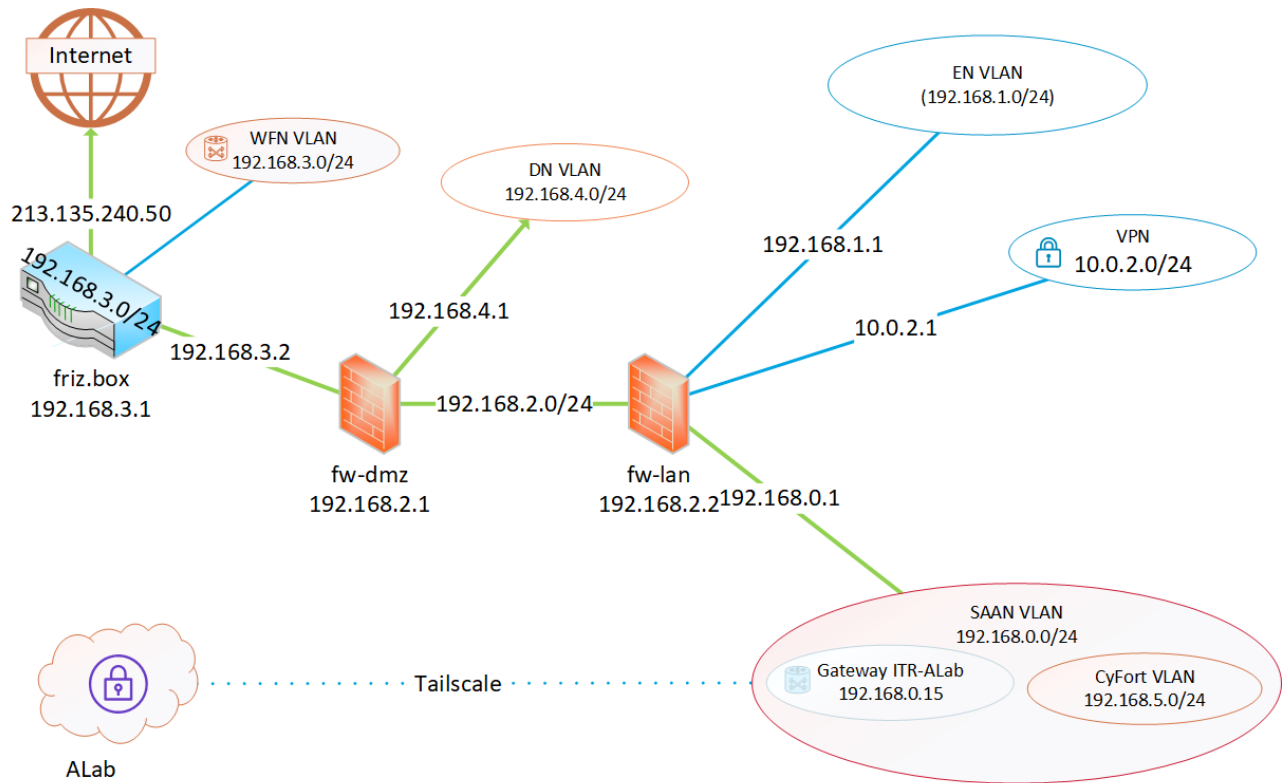


Figure 5: SAAN white rules

3.1.3 From the VN

Components connected through the VPN can access the services provided by the SAAN and the Internet. As for components located within the EN, access to the services provided by the DN is made through the reverse proxy of the SAAN.

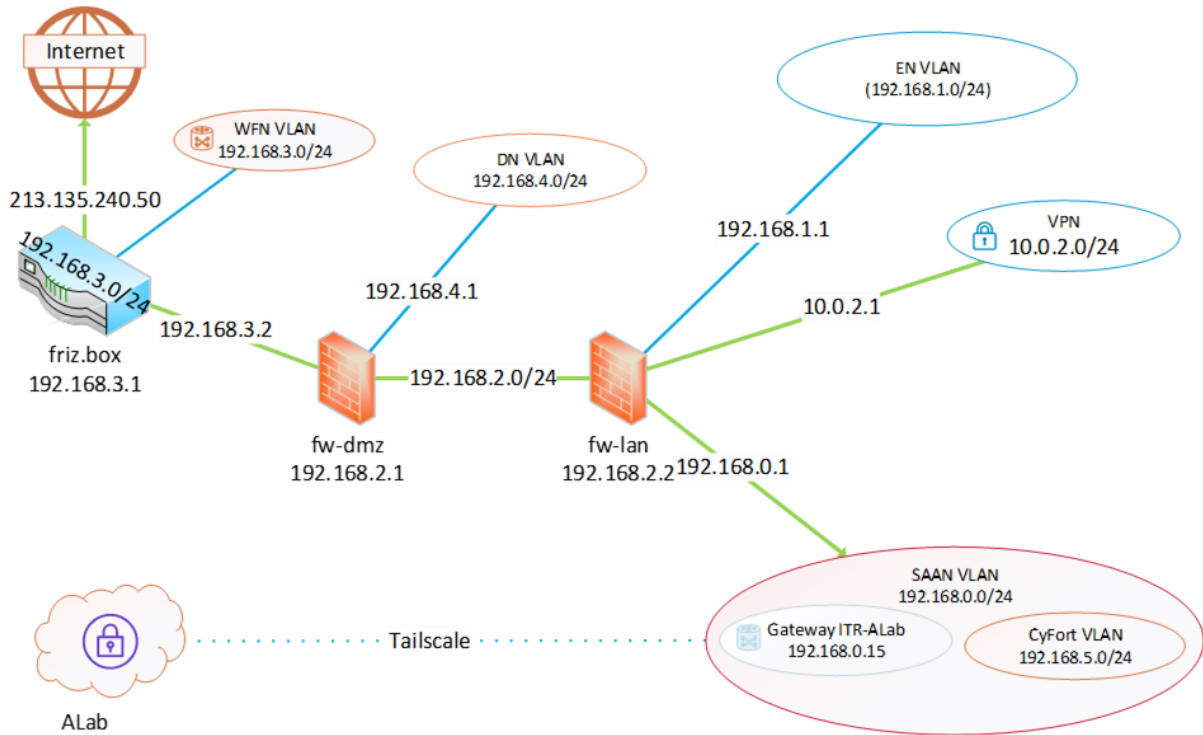


Figure 6: VN white rules

3.1.4 From the WFN

From the WFN, components can only access the Internet. Employees connected to the WFN must use the VPN connection in order to access the services provided by the SAAN and the DN.

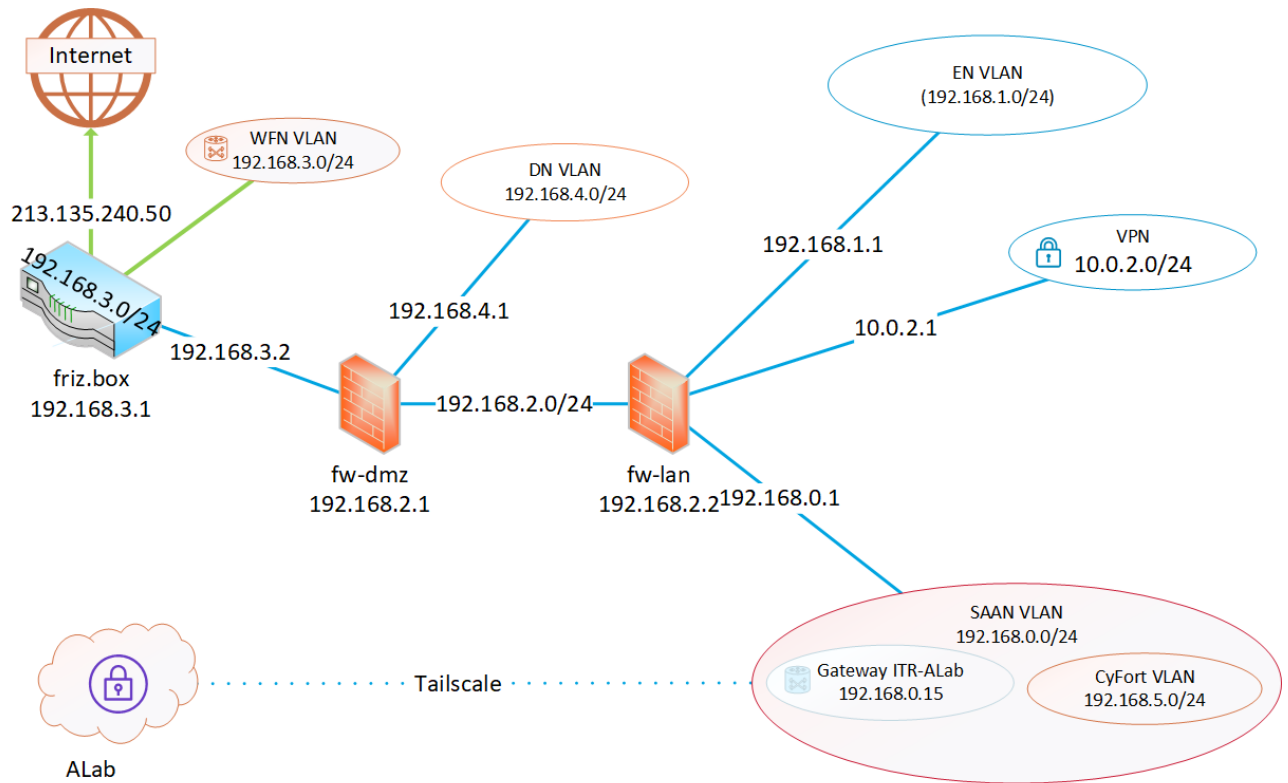


Figure 7: WFN white rules

3.1.5 From the DN

From the DN, most of components can only access the Internet, only few have access to the specific SAAN services:

- Wazuh agents to vm-lan-monitorer;
- App TRICK Service to Redmine;
- Burp client to vm-lan-backuper;
- Gitlab from DN.

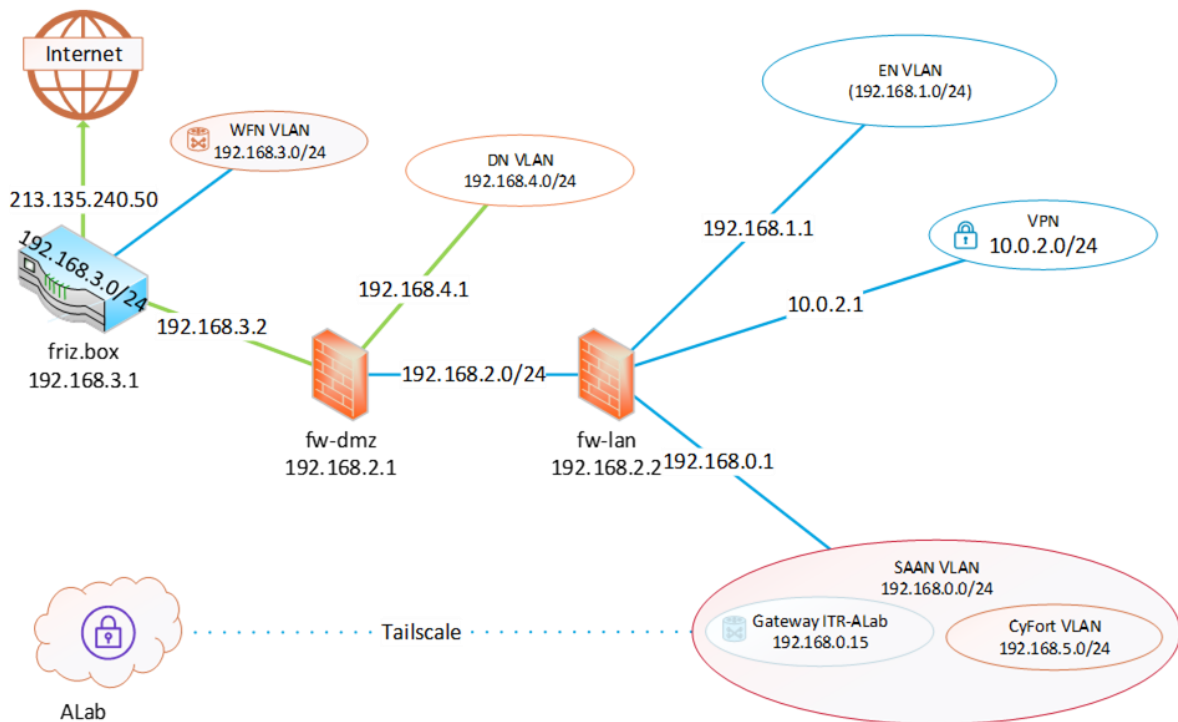


Figure 8: DN white rules

3.1.6 From the Internet

As some services are provided to the Internet by the DN, the following complementary white rules are applied on the firewalls.

fw-dmz is connected directly to the Router (fritz.box) and accepts and forwards VPN connections from the Internet to the second firewall. It also authorises and forwards connections coming from the Internet on port 443 and 80 to the Front-End server located in the DN.

fw-lan: this firewall is connected behind the fw-dmz firewall. It accepts VPN connections and SSH connections coming from the fw-dmz. SSH server only accepts connections using public key authentication.

3.1.7 From ALab to itrust

Employees of ALab (Abstraction labs) connect to CyFORT VLAN network through tailscale. The gateway ITR-Alab (192.168.0.15 - vm-lan-bastion-cyfort.itrust.lu) is used to connect and filter traffic between two network segments.

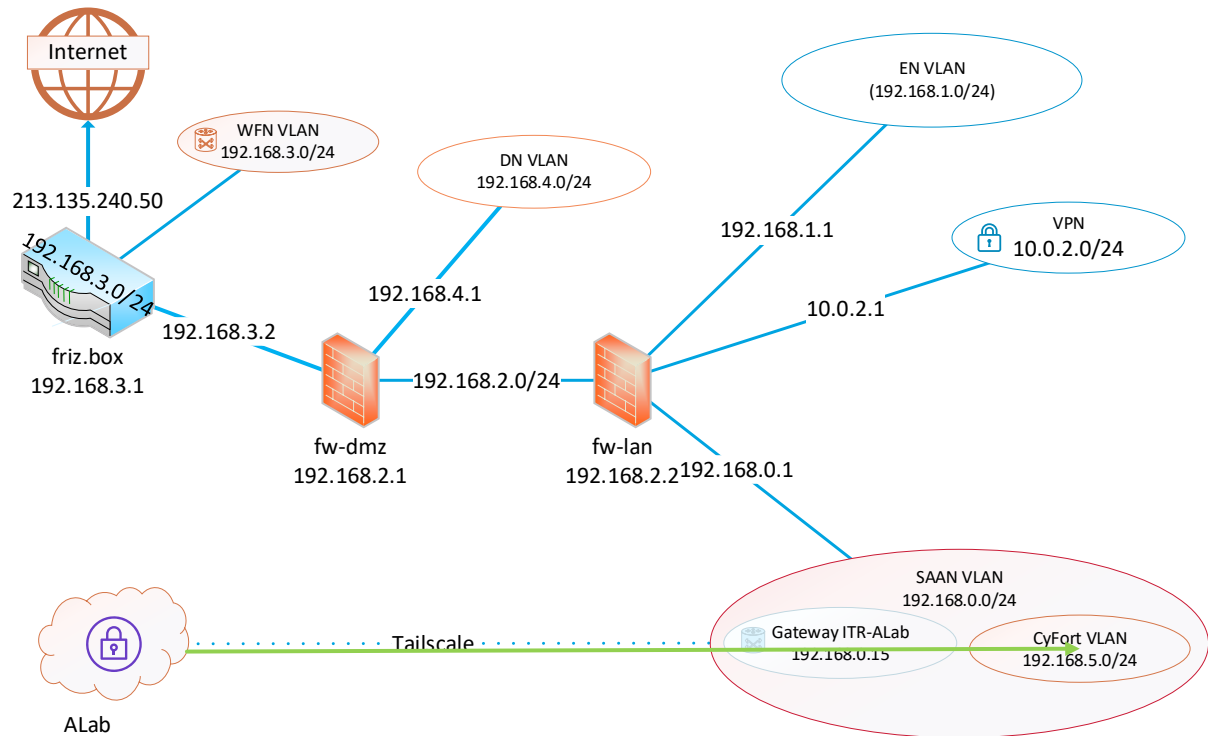


Figure 9: Network flow from ALab to itrust

3.2 From itrust to ALab

itrust employees connect to ALab (Abstraction labs) services via the gateway ITR-Alab (192.168.0.15 - vm-lan-bastion-cyfort.itrust.lu)

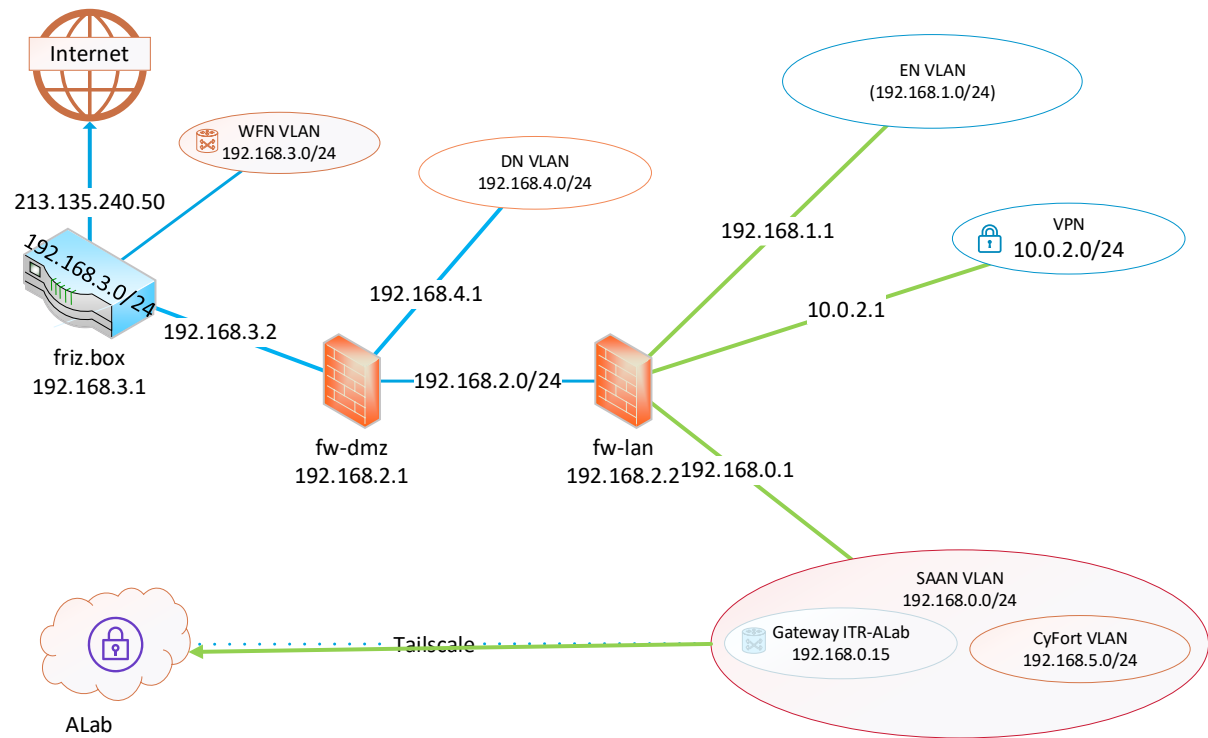


Figure 10: Network flow itrust to ALab

3.3 Opened ports

The following table summarises what ports are open/listening to the Internet.

Service	Ports
VPN	UDP/5443
EpStan VPN	UDP/43490
Web	TCP/443, TCP/80
SSH	TCP/8609
ÉpStan service	TCP/2000, TCP 2001

Table 2: Open/listening ports on the Internet

3.4 Proxy

A proxy is installed on the fw-lan, which is responsible for logging what web content is accessed by employees and administrators from the EN, SAAN, and VN. It blocks web content which seems to be vectors of spreading malware, based on an updated malware blacklist.

3.5 VPN access

A VPN access has been implemented on the fw-lan firewall in order to provide access to services of the SAAN to the employees when they are outside of the itrust consulting network. The VPN server requires a

strong authentication (each employee has a certificate) before authorizing clients to be connected. When connected to the VPN, all flow between the client and the VPN server is encrypted.

3.6 HTTPS

All services requiring authentication process or transmitting confidential information provided by itrust consulting network (from DMZ or from SAAN) are protected using HTTPS.

3.7 Reverse proxies

Reverse proxies are used to provide internal services of itrust consulting (DMZ and SAAN) to customers and employees:

- one reverse proxy is installed on the fw-lan. This reverse proxy manages web connections from the EN or from the SAAN to the DN or to the SAAN;
- another reverse proxy is installed on the fw-dmz. This reverse proxy manages web connections from the Internet to the DN.

3.8 Monitoring of the network

Wazuh used to centralise and monitor network and host activities. Concretely, servers will collect logs during their operation, and send them to a dedicated server running Wazuh. It enables to make research and present log data with graphics. There are some open ports in Wazuh to collect data from itrust cloud services and these ports are restricted the itrust cloud IPs.

3.9 Deployment server scheme

In the context of software development, three types of servers will operate within the itrust consulting network:

- development server: this type of server is run by developers on their own machine and enables them to test immediately if new or modified features work as planned;
- testing server: this type of server is run by a server on the hypervisor of the SAAN. It enables Product Owners to validate modifications made by developers. It is run on SAAN, as non-validated services should not be accessible on the DN. Access from outside can be made through VPN connection;
- production server: this type of server runs the validated version of services developed by itrust consulting. Two production servers will be available, one on the SAAN and one on the DN. Each production server can operate several services but services that do not require to be provided to the Internet should stay on the SAAN.

4 Technologies

The following table summarises what technology will be used for different needs in components.

Need	Technology	Description
Differential backup	Rsync / Borg backup [14]/ Burp Backup	Backup of data from SAAN and DN NAS to the Berbourg NAS.
Domain controller	Samba [15] / LDAP	Access control of data provided by the share server.
Encryption	Cryptsetup/LUKS [16] Bitlocker	Protect data stored by the different NAS. Full-disk encryption feature to protect data by encrypting the entire drive where Windows and user data are stored.
Firewall	Netfilter / iptables [17]	Protect network access to the servers.
Monitoring	Icinga [31]	Monitor the availability of services from outside or inside.
Java virtual machine	OpenJDK [18]	Running software developed under Java EE.
Log centralisation	Rsyslog [19]	Sending log activities of one host to the centralised logging server.
Loadbalancer	HAproxy [32]	Loadbalancer for EpStan
Log real-time and historical search	Wazuh [30]	Monitoring and analysis of the network and host activities. Wazuh is used for monitoring websites and network logs.
Proxy	Squid [21]	Analysing web user traffic and preventing users access to malware. Squid is currently disabled #6758 created for reinstalling.
Reverse proxy	Apache HTTP server [22]	Providing different web services to the Internet and to the EN.
Revision control softwares	Gitlab [23] Github [33]	Versioning of source code between different developers.
Server OS	Debian Ubuntu [24]	Operating system.
Linux shell	ZSH [26] / Bash	Controlling command line.
Microsoft shell	MS Powershell	Microsoft scripting language and command-line interface. Used in ITR systems for task automation, system management, and configuration such as GPOs, some management scripts, etc.
Virtualisation	VirtualBox [27] / KVM	Hosting several virtual machines on unique physical machine.
VPN	WireGuard [28]	Enabling outside employees' access to the SAAN services.
Web server	Apache HTTP server [22]	Operating web applications.
Website content control	Squidguard [29]	Analysing web user traffic and preventing users' access to malware.
Database	Maria DB / MySQL /Postgres SQL	Database management system
Containerization	Docker [34]	Launching applications in software containers

	Kubernetes [35]	
--	-----------------	--

Table 3: Technologies used